INFORME DE PRUEBA SUSTANTIVA

Informe de Prueba Sustantiva: Verificación de Controles de Acceso en Endpoints del Sistema – OWASP A01:2025

Fase 1 · Acceso anónimo · Caja negra · DAST

1. Resultado ejecutivo

Resultado general: NO CONCLUYENTE PARA A01. No se confirmó acceso indebido a datos protegidos en las respuestas examinadas. Tampoco existe evidencia suficiente para declarar que el sistema cumple sus controles de acceso.

Las 15 rutas solicitadas respondieron HTTP 200 con Content-Type text/html y 7.541 bytes. El cuerpo es idéntico, byte a byte, al de la página principal y al de una ruta de control diseñada como inexistente. Python Requests e Insomnia 13.3.0 reprodujeron el mismo resultado. Este comportamiento es consistente con el fallback de la SPA.

Se conservaron 34 respuestas HTTP principales satisfactorias, 51 capturas originales de Insomnia y 68 aserciones de instrumentación aprobadas. Estas aserciones comprueban el registro de la respuesta; no son 68 pruebas de autorización ni certifican cumplimiento de OWASP.

2. Datos de la prueba

Campo	Detalle
Sistema	Panificadora Nancy
Destino	https://www.panificadoranancy.com
Referencia	OWASP Top 10:2025, A01 — Broken Access Control [R1]
Modalidad	Caja negra; DAST acotado; método GET; usuario anónimo
Fecha / zona	7 de octubre de 2026 · America/La_Paz (UTC−04:00)
Herramientas	Insomnia 13.3.0; Python 3.14.7; Requests 2.34.2; Playwright para operar y capturar la interfaz
Responsabilidad	Ejecución técnica asistida por Codex. Responsable académico y revisor: por completar por el usuario.
Alcance acordado	Solo acceso anónimo. Las pruebas con cuentas e IDOR se pospusieron por indicación expresa del usuario.

3. Objetivo, alcance y criterio

Verificar si las rutas indicadas permiten obtener información protegida sin autenticación y diferenciar respuestas de datos de documentos de presentación. La evaluación de funciones y objetos protegidos requiere identificar sus endpoints reales de API y contar con identidades y objetos de prueba controlados.

El alcance comprende 15 rutas proporcionadas por el usuario y 2 controles de comparación. No se consultó el código fuente, configuración del servidor, repositorio o base de datos de la aplicación auditada. Los archivos locales de Insomnia se usaron únicamente para conservar solicitudes, respuestas y resultados de la herramienta.

Respuesta observada	Interpretación de auditoría
401 / 403	Bloqueo HTTP observado para esa solicitud; no demuestra por sí solo protección de todos los roles, funciones o métodos.
404 / 405 / 3xx	Recurso ausente u ocultado, método no permitido o redirección. No permiten un dictamen global. Las redirecciones se mantienen sin seguir.
200 con HTML	Inspeccionar el contenido. HTML puede contener datos privados; no se presume automáticamente que sea una SPA.
200 con HTML idéntico a ambos controles y contenedor de aplicación vacío	Evidencia de documento común de la SPA. No demuestra acceso al recurso protegido ni valida su API.
2xx con JSON u otro contenido	Revisar sensibilidad, política de acceso e identidad. El formato o el éxito HTTP por sí solos no confirman A01.

4. Procedimiento aplicado

1. Se preparó una colección local separada con 17 solicitudes GET. Sin credenciales, variables con tokens, encabezado Authorization ni Cookie. El envío y almacenamiento de cookies y el seguimiento de redirecciones están desactivados en cada solicitud.
2. Se ejecutó Python Requests con una sesión nueva por solicitud, trust_env=False, sin credenciales .netrc, con validación TLS y una pausa de 0,8 s entre solicitudes. Se guardaron cuerpos, cabeceras, tiempos y huellas SHA-256.
3. Se ejecutaron las mismas rutas en Insomnia con Pre-request de limpieza de cabeceras y After-response de clasificación. El timeline confirma la ausencia de Authorization y Cookie; la validación TLS se mantuvo activada.
4. Se capturaron Preview en modo Source Code, Headers y Tests para cada respuesta. Las imágenes provienen de la interfaz real y no fueron editadas. Se conservaron los resultados de los scripts y la traza HTTP de Insomnia.
5. Se compararon los bytes de los 34 cuerpos y se revisó el HTML común. Contiene metadatos públicos, JSON-LD promocional, un módulo JavaScript referenciado y un elemento div con id root vacío; no contiene listados privados de pedidos, clientes o inventario.

Incidencia de ejecución: el primer intento de Python falló por resolución DNS dentro del entorno restringido, antes de obtener respuesta HTTP. Se conserva separado y no se incluye en las 34 respuestas válidas. La ejecución con acceso de red autorizado completó el lote.

5. Resultados consolidados por endpoint

Todas las filas corresponden a GET sin autenticación y cuerpos de 7.541 bytes. Criterio esperado: no entregar datos protegidos al usuario anónimo. P/I indica el estado HTTP obtenido en Python e Insomnia. Cada ID vincula tres capturas y las evidencias originales.

ID	Endpoint	HTTP P/I	Tipo	Resultado
A01-01	/pedidos	200/200	text/html	No concluyente / SPA
A01-02	/mis-pedidos	200/200	text/html	No concluyente / SPA
A01-03	/admin	200/200	text/html	No concluyente / SPA
A01-04	/admin/usuarios	200/200	text/html	No concluyente / SPA
A01-05	/admin/clientes	200/200	text/html	No concluyente / SPA
A01-06	/admin/productos	200/200	text/html	No concluyente / SPA
A01-07	/admin/pedidos	200/200	text/html	No concluyente / SPA
A01-08	/admin/categorias	200/200	text/html	No concluyente / SPA
A01-09	/inventario	200/200	text/html	No concluyente / SPA
A01-10	/inventario/materias-primas	200/200	text/html	No concluyente / SPA
A01-11	/inventario/producciones	200/200	text/html	No concluyente / SPA
A01-12	/inventario/movimientos-caja	200/200	text/html	No concluyente / SPA
A01-13	/user	200/200	text/html	No concluyente / SPA
A01-14	/me	200/200	text/html	No concluyente / SPA
A01-15	/profile	200/200	text/html	No concluyente / SPA

5.1. Controles de comparación

ID	Ruta	Obtenido
CTRL-01	/	200 HTML / 7.541 bytes
CTRL-02	/__a01_control_inexistente_20261007_7e6a12	200 HTML / 7.541 bytes

Los 34 cuerpos comparten la siguiente huella SHA-256:

`190646cf684af636c9eac7ea7ffbf2c76986f1d689146c6ff7fd15d8866584a7`

Conclusión técnica: se observó un documento HTML común incluso para el control inexistente. Se infiere un fallback de la SPA a partir del comportamiento externo; no se afirma haber inspeccionado la configuración del servidor.

6. Hallazgos, límites y pruebas pendientes

OBS-A01-01 — Documento HTML común en rutas de navegación. Tipo: observación técnica, sin vulnerabilidad A01 confirmada. Severidad/CVSS: no asignados. Evidencia: matriz de resultados, comparación de cuerpos y capturas asociadas.

El HTTP 200 observado no prueba que un usuario anónimo haya obtenido un pedido o información administrativa. No corresponde clasificar estas respuestas como “No cumple”. La ausencia de datos privados en el documento común tampoco acredita que la API aplique controles de acceso correctos; por ello no corresponde clasificarlas como “Cumple”.

6.1. Cobertura no evaluada

Prueba pendiente	Estado y condición necesaria
Acceso anónimo a APIs reales de datos	Pendiente: identificar URLs y métodos a partir del tráfico normal del cliente o de documentación autorizada; las rutas de navegación no identifican por sí solas las APIs.
Escalamiento vertical / BFLA	No ejecutado por alcance acordado. Requiere una cuenta cliente válida y una función administrativa identificada. Primero confirmar que la sesión sea válida mediante un control positivo.
IDOR / BOLA entre A y B	No ejecutado por alcance acordado. Requiere dos cuentas propias y un objeto conocido de cada una; probar la lectura cruzada y contrastar con la lectura legítima.
Manipulación de identificadores	No ejecutada. Usar identificadores de objetos de prueba autorizados; no se realizó un barrido de IDs ajenos.
Otros métodos y escenarios	No evaluados: POST, PUT, PATCH, DELETE, sesiones autenticadas, cambios de roles, escritura, eliminación, endpoints no incluidos ni configuración interna.

6.2. Recomendaciones

- Continuar en el mismo informe con endpoints de API observados y una matriz de permisos esperados por identidad, función y objeto.
- Comprobar la autorización en el servidor para cada función y cada objeto protegido, además de cualquier restricción visual del frontend. Este es un criterio de evaluación recomendado por OWASP [R1], no una deficiencia comprobada en este sistema.
- Cuando se amplíe el alcance, comparar la respuesta legítima del propietario con la respuesta de otra cuenta de prueba y con la del usuario anónimo. Conservar códigos, contenido pertinente y contexto sin incluir tokens en el informe.
- Mantener el estado global “No concluyente” hasta reunir evidencia suficiente. Un acceso indebido confirmado justificaría “No cumple” para el control afectado; completar esta muestra sin hallazgos no equivale a certificar todo el sistema.

7. Evidencias y trazabilidad

Python: 2026-10-07T00:20:11-04:00 a 2026-10-07T00:20:34-04:00. Insomnia (fecha de registro de respuestas): 07/10/2026 00:23:35 -0400 a 07/10/2026 00:26:46 -0400. Las horas de cada captura se encuentran en el índice, con desplazamiento UTC−04:00.

Archivo o carpeta	Contenido
capturas/	51 PNG originales: 3 por cada una de las 15 rutas y los 2 controles. Ejemplo: A01-02_preview.png, A01-02_headers.png y A01-02_tests.png.
capturas/ indice_capturas.json	Relación URL, ID de solicitud/respuesta de Insomnia, vista, fecha de captura y hashes de respuesta e imagen.
evidencias/insomnia/	Por cada ID: cuerpo .body, cabeceras/resultados .response.json, solicitud .request.json, traza .timeline y textos de accesibilidad .ui.txt.
Lote Python válido	evidencias/python_20261007_002011/ — Resultados TXT, CSV y JSON; cuerpo y metadatos por solicitud.
Resumen y tabla CSV	evidencias/resumen_consolidado.json y evidencias/tabla_resultados_A01.csv: comparación entre herramientas.
Colección de Insomnia	coleccion_insomnia/A01_Nancy_anonimo.insomnia.json. Incluye Pre-request y After-response, sin credenciales.
scripts/	Enumeración acotada, scripts de Insomnia, automatización de capturas y generación del informe.
MANIFIESTO_SHA256.txt	Huellas de los archivos entregables para detectar cambios posteriores. No constituye certificación de fecha por un tercero.

7.1. Lectura correcta de las capturas

Preview muestra el HTML recibido en modo Source Code, sin confundir la representación visual con datos de API. Headers muestra Content-Type y las cabeceras del servidor. Tests muestra 4/4 aserciones de registro aprobadas; la propia etiqueta aclara “no certifica A01”.

La pestaña Auth muestra “Inherit from parent”; el perfil Scratch Pad no tiene credenciales de padre ni entorno con secretos. La ausencia efectiva de autenticación está comprobada en las cabeceras salientes del timeline y en la configuración de cada solicitud; no se deduce únicamente del icono de la interfaz.

Las imágenes seleccionadas de las páginas siguientes son una muestra. La cobertura completa está en las 51 capturas externas. Para inspeccionar el texto pequeño, abrir el PNG original o ampliar el PDF. El informe previo hallado en la carpeta se conservó sin cambios y no se usó como evidencia de Panificadora Nancy.

8. Referencias y cierre

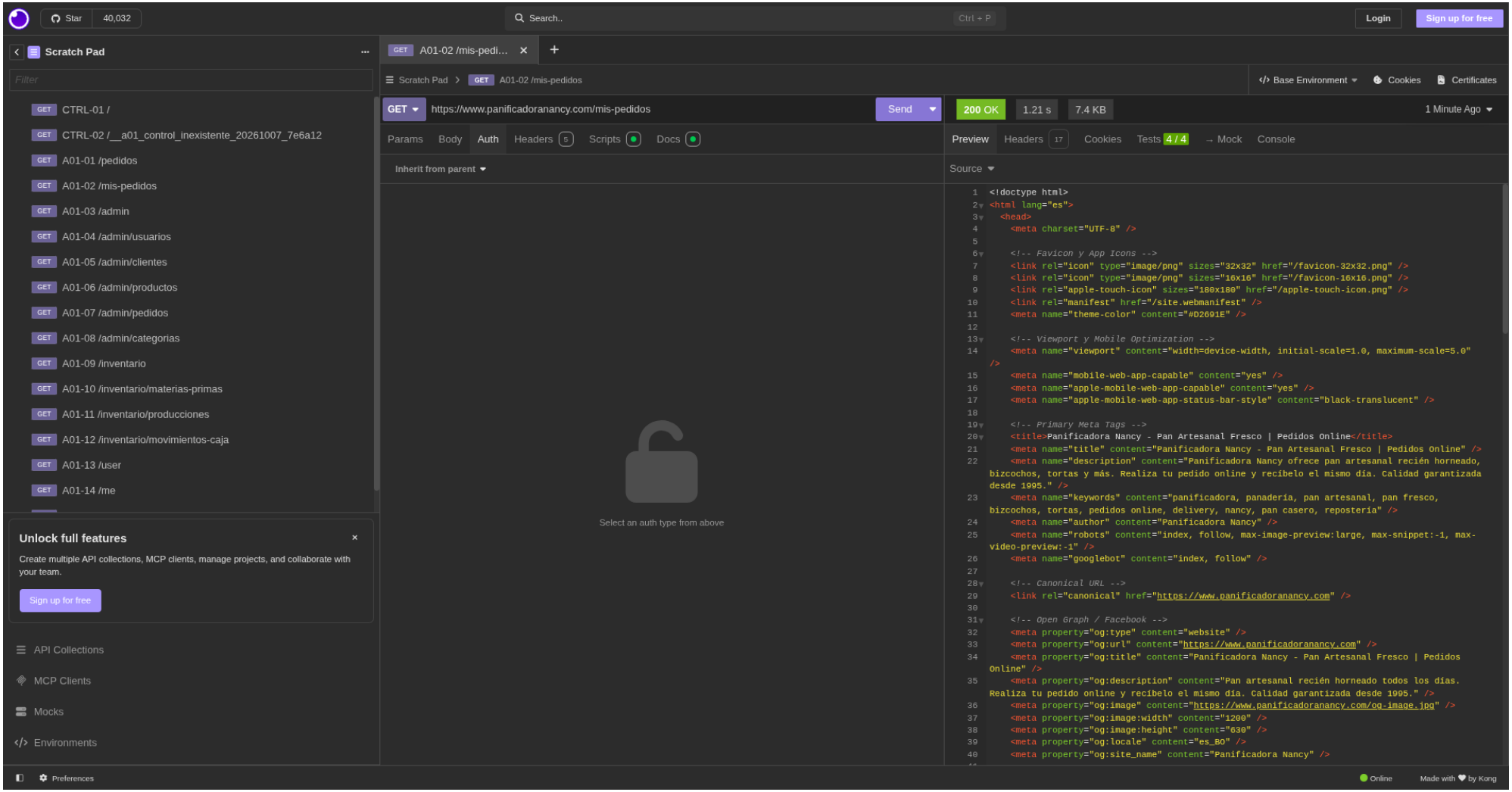
[R1] OWASP Top 10:2025 — A01 Broken Access Control. https://top10.owasp.org/2025/A01_2025-Broken_Access_Control/ (consulta: 07/10/2026).

[R2] Kong — Scripts in Insomnia. https://developer.konghq.com/insomnia/scripts/ (consulta: 07/10/2026). Se emplearon sus interfaces de respuesta y pruebas para registrar la evidencia.

Dictamen de esta fase: NO CONCLUYENTE PARA A01. Fallback HTML observado; ningún acceso indebido confirmado en las respuestas estudiadas; control de acceso de APIs y sesiones pendientes de evaluación.

E1 · /mis-pedidos — Preview del HTML

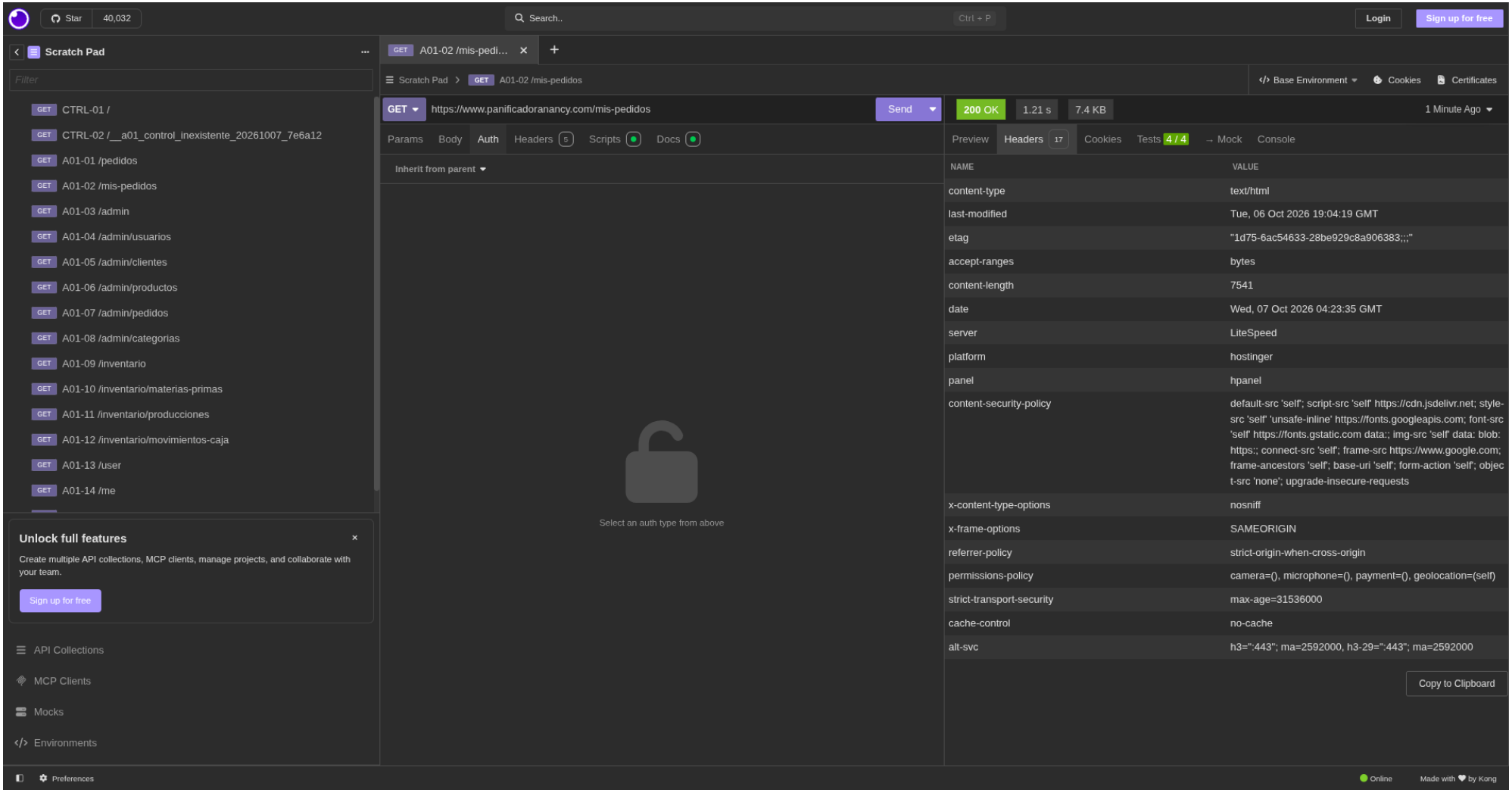
La ruta devuelve un documento HTML con metadatos de la aplicación. El contenido completo se conserva como A01-02.body.



Original: capturas/A01-02_preview.png · Capturada: 2026-10-07T00:24:54-04:00

E2 · /mis-pedidos — Cabeceras

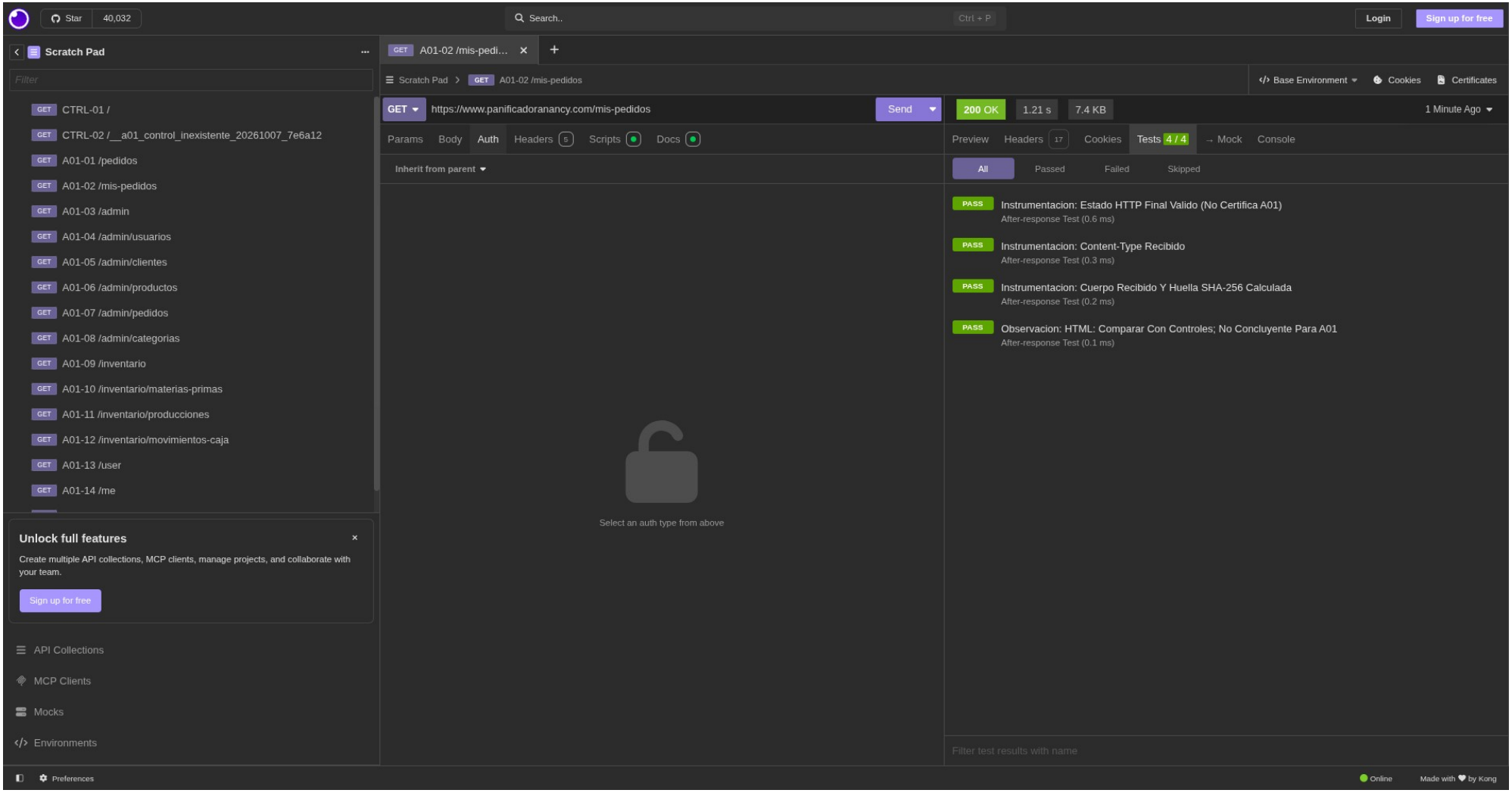
HTTP 200 y Content-Type text/html; el tamaño íntegro observado es de 7.541 bytes.



Original: capturas/A01-02_headers.png · Capturada: 2026-10-07T00:24:54-04:00

E3 · /mis-pedidos — Tests After-response

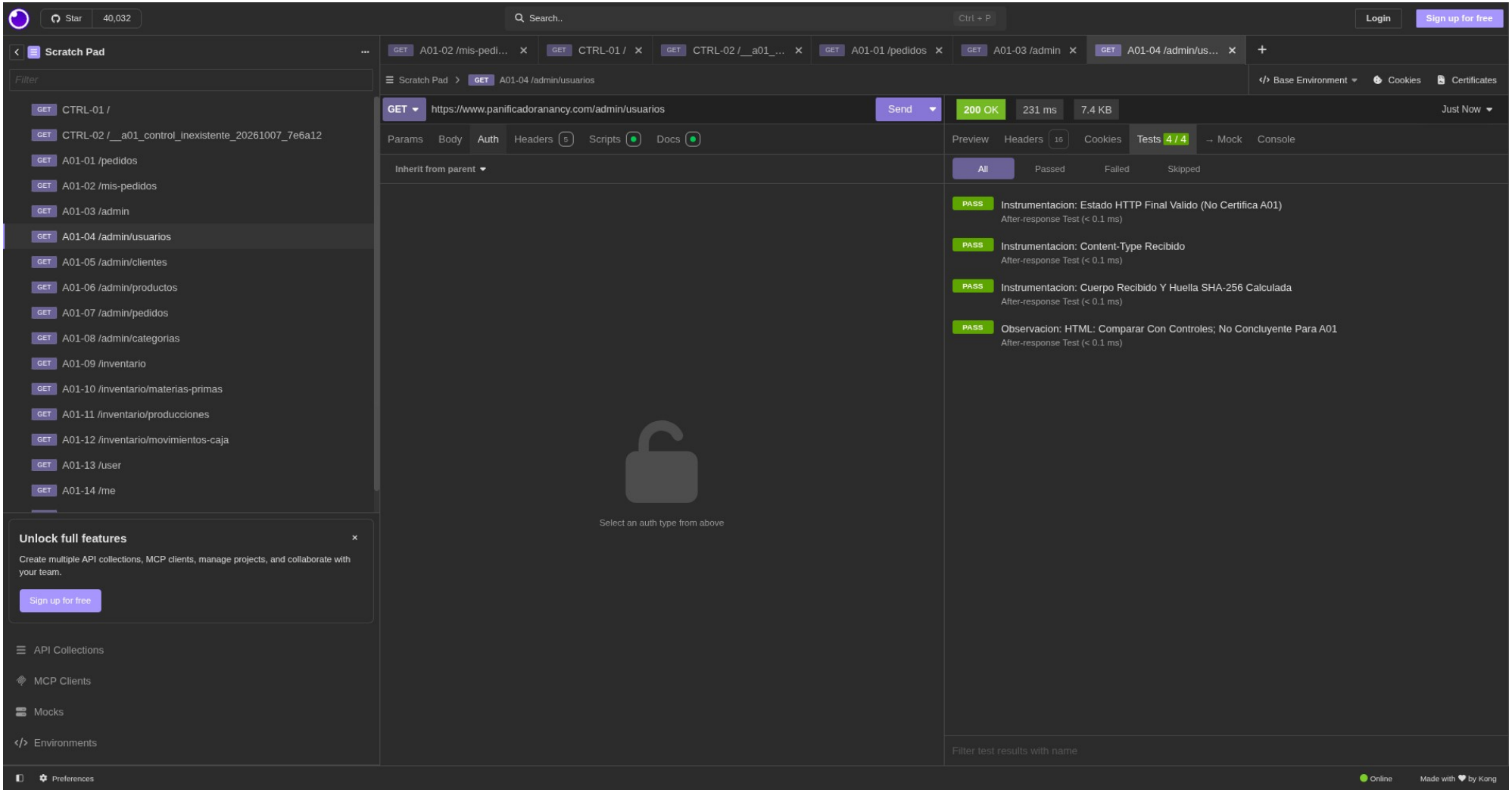
Los cuatro resultados PASS corresponden a instrumentación. La clasificación indica que el HTML no es concluyente para A01.



Original: capturas/A01-02_tests.png · Capturada: 2026-10-07T00:24:55-04:00

E4 · /admin/usuarios — Tests After-response

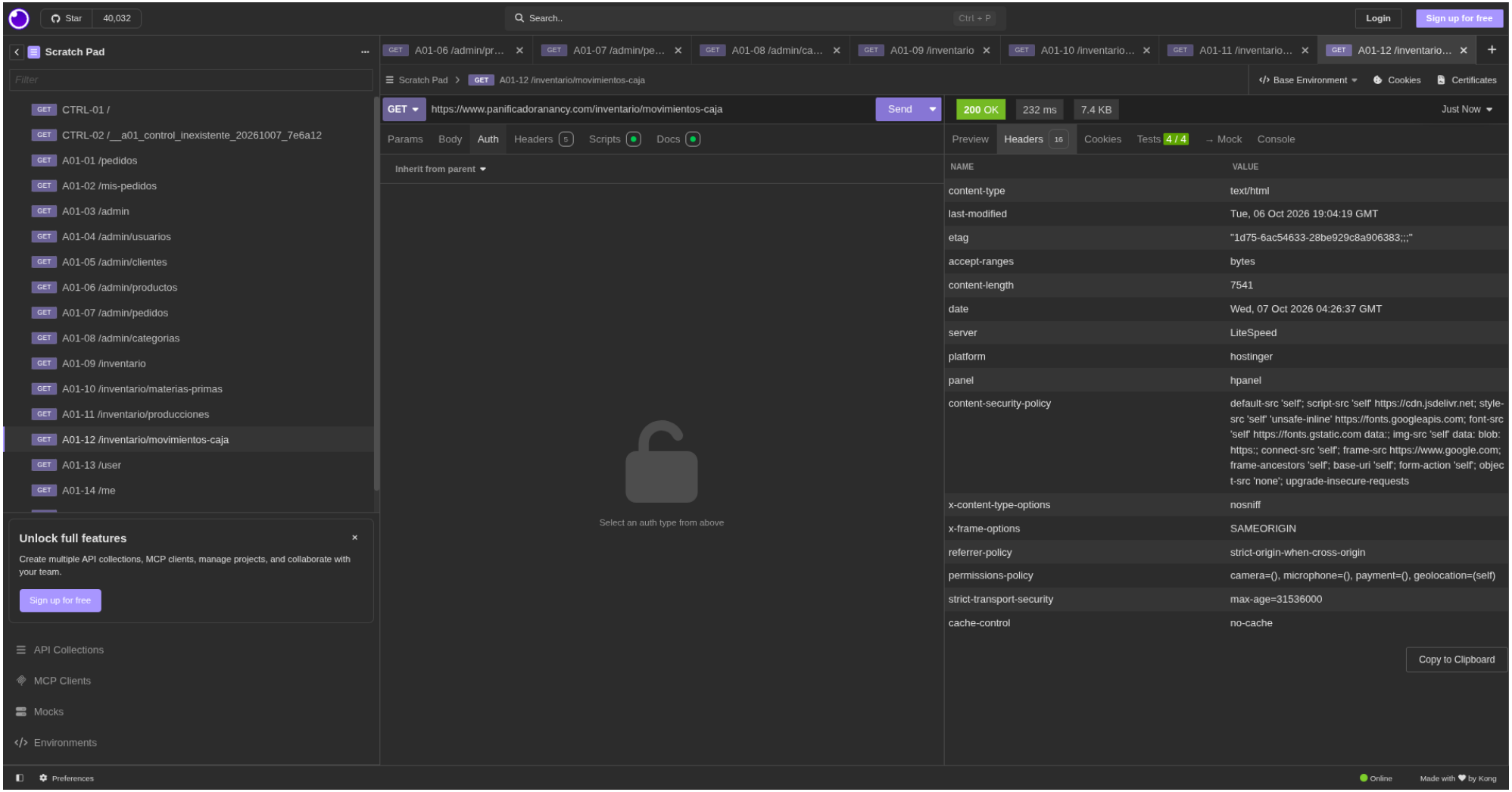
Acceso anónimo a una ruta de navegación administrativa. El cuerpo coincide con el documento de la SPA, sin demostrar acceso a una API administrativa.



Original: capturas/A01-04_tests.png · Capturada: 2026-10-07T00:26:17-04:00

E5 · /inventario/movimientos-caja — Cabeceras

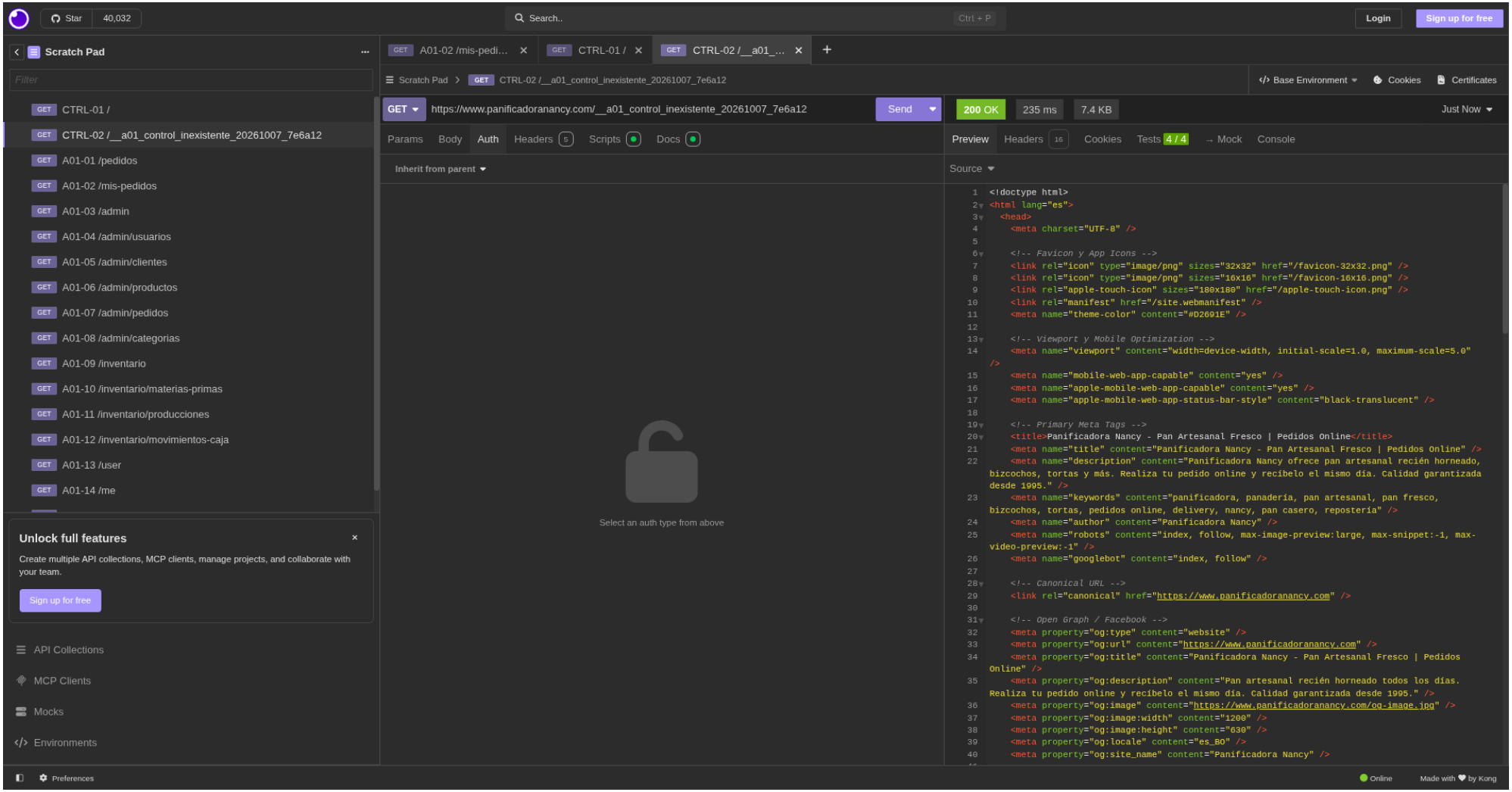
La ruta de inventario muestra el mismo comportamiento HTTP/HTML. No se obtuvo un listado de movimientos de caja en el cuerpo observado.



Original: capturas/A01-12_headers.png · Capturada: 2026-10-07T00:26:39-04:00

E6 · Ruta de control inexistente — Preview

También recibe el documento común. La igualdad de SHA-256 con raíz y rutas evaluadas sustenta la inferencia de fallback.



Original: capturas/CTRL-02_preview.png · Capturada: 2026-10-07T00:25:20-04:00